

SIMATS ENGINEERING

ASSESSMENT TOOL 3 – Scenario-Based

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

CO2 | Weightage: 30% | Duration: 90 min | Total Marks: 50

COURSE OUTCOME COVERED

CO2: Foot printing Tools – Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

QUESTIONS

Topic 1: Footprinting Tools – Conducting Competitive Intelligence

Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named

ABC Technologies. The consultant must collect publicly available information without directly interacting

with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

- o domain registration details,
- o employee email addresses,
- o technology stack,
- o and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

Topic 2: DNS Zone Transfers

Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is

misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the

transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers,

and subdomains during reconnaissance.

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify

their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees

should follow before responding to the email. Explain how these actions help prevent credential theft.

Code of Conduct:

I B.Muni Chandini (192524283) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: *B.Muni Chandini*

ANSWERS

Q1. Footprinting Tools – Competitive Intelligence

Scenario: A cybersecurity consultant must perform a passive security assessment for ABC Technologies. Only publicly available information is to be collected (no direct interaction with company servers).

1.1 Understanding the Requirement

Passive footprinting means gathering information from open sources without sending packets to the target. This is standard for competitive intelligence and early reconnaissance in authorized assessments.

1.2 Tools and Their Use

Domain registration details

- Tool: WHOIS (whois command / whois.icann.org / whois.com)
- What it reveals: Registrar, registrant organization, creation/expiry dates, name servers, sometimes admin contact.
- Value for competitive intelligence: Confirms ownership, age of domain, and related domains registered by the same entity.

Employee email addresses

- Tool: theHarvester (or public search / LinkedIn / company website “Contact” and “Team” pages)
- What it reveals: Email patterns (e.g., firstname.lastname@abctech.com), employee names linked to the company.
- Value: Helps map organizational structure and later identify possible phishing targets in authorized tests only.

Technology stack

- Tool: BuiltWith, Wappalyzer, or WhatWeb
- What it reveals: Web server, CMS, frameworks, analytics, CDN, programming languages used on public sites.
- Value: Shows which technologies the company relies on; useful for understanding public attack surface without active scanning.

Publicly exposed subdomains

- Tool: Sublist3r, Amass (passive modes), or Certificate Transparency logs (crt.sh)
- What it reveals: Subdomains such as mail., vpn., dev., staging. that appear in public DNS or certificates.
- Value: Expands the known public footprint and may reveal forgotten or less-protected systems.

Passive Footprinting for Competitive Intelligence

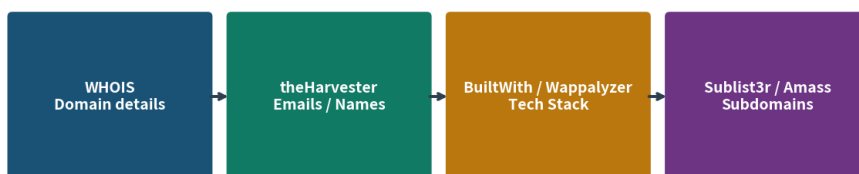


Figure 1: Common passive footprinting tools used for competitive intelligence

1.3 How These Tools Support Competitive Intelligence

Together they give a public picture of the organization's online presence, technology choices, and contact surface. This information is collected only from public sources and is used in authorized assessments to understand exposure without touching the target systems.

Q2. DNS Zone Transfers

Scenario: During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

2.1 Understanding the Issue

A DNS zone transfer (AXFR) is the method used by secondary name servers to copy the full zone data from a primary server. When zone transfers are not restricted, any external host can request the complete list of DNS records. This is a classic misconfiguration found during authorized reconnaissance.

2.2 Appropriate Command / Tool to Verify

Step 1 – Identify the authoritative name servers:

- `nslookup -type=NS targetdomain.com`
- `dig NS targetdomain.com`

These commands return the list of name servers (NS records) responsible for the domain.

Step 2 – Attempt a zone transfer against each name server:

- `dig axfr @ns1.targetdomain.com targetdomain.com`
- `host -l targetdomain.com ns1.targetdomain.com`

If the server is properly locked down, the response will be "Transfer failed" or "REFUSED". If the transfer succeeds, the full zone file is returned. These checks are performed only inside an authorized penetration test scope.

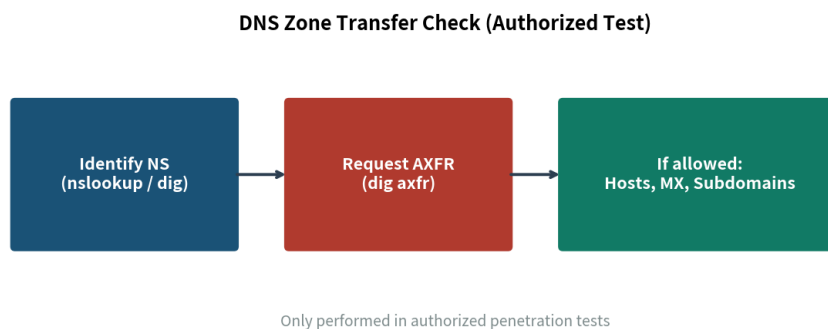


Figure 2: High-level steps to check for open zone transfer (authorized testing only)

2.3 What Retrieved DNS Records Reveal

When an unauthorized zone transfer is possible, the analyst receives a complete map of the DNS zone. The most useful record types for reconnaissance are:

- A and AAAA records – Link hostnames to IPv4/IPv6 addresses. This quickly lists internal or publicly reachable hosts (web, app, database, jump servers, etc.).
- MX records – Identify the mail servers that handle email for the domain. These become important targets for further authorized email-related testing.

- NS and CNAME records – Show additional name servers and aliases. Aliases often point to staging, development, or CDN systems that may be less hardened.
- TXT records – May contain SPF, DKIM, verification tokens, or other configuration data that reveals email security posture.
- SRV records (if present) – Can expose service locations such as VoIP, directory services, or collaboration tools.
- Subdomain names – Every hostname in the zone expands the attack surface map and helps the tester prioritize systems for later phases.

2.4 How This Helps Reconnaissance

The zone file acts as an internal directory of systems. From it the authorized tester can:

- Build a complete list of hosts and their IP addresses without active network scanning.
- Identify mail infrastructure for later authorized testing.
- Discover forgotten or poorly maintained subdomains (dev, test, backup, old applications).
- Understand the organization's naming conventions, which often reveal department or function.

All of this information is obtained passively from the DNS server once zone transfer is allowed, making it highly valuable in the reconnaissance phase of an authorized assessment.

2.5 Recommended Fix (for the report)

Zone transfers should be restricted to a short list of trusted secondary name servers only. Public or unrestricted AXFR must be disabled. This finding should be reported as a medium-to-high severity misconfiguration.

Q3. Social Engineering – Phishing Attack & Countermeasures

Scenario: Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

3.1 Identification of the Attack

This is a Phishing attack, specifically a credential-harvesting phishing email. It belongs to the broader category of social engineering attacks.

Key indicators that confirm the attack type:

- Impersonation – The message pretends to come from the internal IT department, a trusted source.
- Urgency – Language such as “urgent security update” is designed to push the user into acting without thinking.
- Request for credentials – The email asks the user to enter login details on a link, which is never a normal IT practice for routine updates.
- Unsolicited link – A sudden request to click and verify is a classic phishing pattern.

The goal of the attacker is to steal usernames and passwords so they can access internal systems, email, or cloud accounts.

3.2 Suitable Countermeasures Employees Should Follow

Before responding to or clicking anything in the email, employees should apply the following practical checks:

- Inspect the sender address carefully – Look at the actual email address, not only the display name. A real IT message will normally use the official company domain. Slight spelling changes or free email domains are warning signs.

- Hover over (or long-press) the link – Without clicking, examine the real URL. Look for misspelled domains, strange subdomains, or IP addresses instead of the company name.
- Do not act on urgency alone – Legitimate IT teams almost never demand immediate password entry through an email link for a “security update.” Urgency is a social-engineering pressure tactic.
- Verify through a second channel – Contact the IT helpdesk or security team using a phone number or chat tool that is already known and trusted. Do not use any contact details supplied in the suspicious email.
- Report the message – Forward the email (as an attachment if possible) to the security or IT mailbox so the team can block the sender and alert other staff.
- Never enter credentials on a page reached from an unexpected email – Official password changes or MFA setup are done through known portals or after proper verification.
- Enable and use multi-factor authentication (MFA) – Even if a password is stolen, MFA greatly reduces the chance of account takeover.

Phishing Email – Countermeasures



Figure 3: Practical countermeasures against phishing emails

3.3 How These Actions Prevent Credential Theft

Each countermeasure breaks a step in the attacker's process:

- Checking the sender and the real URL stops the user from reaching a fake login page.
- Resisting urgency removes the emotional pressure that causes people to click without thinking.
- Verifying with IT through another channel confirms whether the request is genuine before any password is typed.
- Reporting the email allows the organization to block the campaign, warn other employees, and reduce the overall success rate of the attack.
- MFA ensures that a stolen password alone is not enough to access the account.

Together, these habits convert a dangerous email into a reported incident instead of a successful credential theft.

3.4 Organizational Support (Additional Context)

While the question focuses on employee actions, organizations also support prevention through security awareness training, email filtering, DMARC/SPF/DKIM, and clear reporting channels. Employee vigilance remains the last and most important line of defense when a phishing email reaches the inbox.

3.5 Conclusion

The described email is a classic phishing (credential-harvesting) social-engineering attack. By carefully checking the sender, inspecting links, refusing to act on false urgency, verifying through a trusted channel,

reporting the message, and using MFA, employees can effectively prevent credential theft and protect both themselves and the organization.

Rubrics Alignment (for examiner reference)

Understanding of Scenario • Identification of Key Issues • Application of Concepts (tools, DNS commands, phishing type) • Decision Making (countermeasures) • Clarity of Response – structured with diagrams.